



Executive summary

AI AGENT + MCP + SKILL SECURITY REVIEW

Scope: Selected source directory; paths below are relative | Invarune 0.15.0

No configured risk patterns detected

The selected static scope completed without a detector match. This is not a security pass. Review the unassessed boundaries and validate the controls below.

0

OPEN FINDINGS

0

COVERAGE GAPS

2

FILES EXAMINED

Observed counts only. This is not an accuracy score or a security grade.

Deterministic layer: Selected static scope completed.

Optional model review: disabled. Deterministic findings and fix guidance run independently.

No open finding groups. Review accepted exceptions, coverage limits and active controls before drawing a deployment conclusion.

[Record a review decision and rescan](#)

Justified and disabled are human decisions, not passes. The full review forms and all evidence remain in this report.

Scan ID: da4d62e183b5547b3271a025705316305a4112899c8b700c67c7ba3805b003dd



Contents

Executive summary	1
Contents	2
Priorities and first actions	3
Metrics and calculation	4
Observed findings and mitigating layers	5
Coverage gaps and required validation	6
Control checklist and evidence requirements	7
Scan configuration and scope	8
Deterministic checks and optional review	11
Coverage, misses and validation by area	12
Appendix / Deterministic rule inventory	14
Interactive review workspace	15



Priorities and first actions

Optional model review: disabled. Deterministic findings and fix guidance run independently.

Severity counts describe observed open patterns. They do not establish exploitability or an estimated probability of compromise.

Critical		0
High		0
Medium		0
Low		0
Info		0

Severity counts use the existing scanner rules; no model or reviewer score is added.

Fix guidance: 0/0 findings have deterministic fix plans and agent/MCP context. Model fix plans: 0/0 finding assessments; 0/0 answered checks. Proposals require verification.

Review every detailed finding and gap below. Additional concerns can exist outside this bounded scan's supported syntax, files, budgets and execution context.



Metrics and calculation

No defensible universal security percentage can be calculated from static patterns or model opinions. Zero findings and 100% answered checks do not mean secure or compliant.

Measure	Result	Interpretation
Open deterministic findings	0 (0 critical/high)	Observed pattern counts. No severity weights or compromise probabilities are assigned.
Partial deterministic mapping reach	100.00% (1/1)	Active selected controls with an active selected mapped rule. Available partial coverage, not a pass rate.
Optional AI answer coverage	0.00% (0/2)	Active selected checks with a model answer, including concerns and unknowns. Review completion, not safety.

Selected scope: 1 rules (1 active); 1 controls (1 active); 2 active acceptance checks. 0 recorded coverage gaps.

Exact formulas

$100 \times \text{active selected controls with at least one active selected mapped rule} / \text{active selected controls}$. This describes partial rule availability, not completed tests, passes, or control effectiveness.

$100 \times \text{unique active selected acceptance checks with a received, valid model answer} / \text{active selected acceptance checks}$. An answer can be a concern or an explicit unknown. Disabled AI has zero answered checks; an empty denominator is not applicable (null), never 100%.

Advisory AI outcomes

Check outcome	Count
supported_by_code	0
potential_gap	0
needs_runtime_validation	0
needs_human_review	0
insufficient_evidence	0
not_applicable_proposed	0
not_reviewed	2

Supported by code and proposed non-applicability are advisory interpretations. Runtime/human validation and missing evidence remain unresolved. AI cannot erase findings, lower their severity, change the severity gate, or turn checks into passes.

Justified and disabled rules/checks are excluded from active metric denominators without pass credit. Findings with user decisions or baseline suppressions remain visible outside open-finding counts. Selection narrows the requested scope; it does not establish the excluded system is safe.

The existing CLI gate uses open deterministic findings at or above the configured severity. Scan/review/export errors can make requested work incomplete. Coverage percentages and model opinions never dismiss the gate.



Observed findings and mitigating layers

No selected static pattern was emitted. Review coverage gaps and control evidence before drawing a conclusion.



Coverage gaps and required validation

No operational gap was recorded within the selected scope. Unsupported runtime properties still require their own checks.



Control checklist and evidence requirements

EXEC-05 / Prevent SSRF and unsafe network destinations

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

[Record review for EXEC-05:1](#)

2. Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

[Record review for EXEC-05:2](#)

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices



Scan configuration and scope

Source scope and limits

Setting	Configured value
Default excluded directories	.cache, .git, .hg, .mypy_cache, .next, .pytest_cache, .svn, .tox, .venv, __pycache__, build, coverage, dist, node_modules, vendor, venv
Exclude	None
Explicit exclusion identity scope	Existing selected files and directories, including case aliases and file hardlinks; inputs must remain stable during the scan. Device/inode identities are not persisted in reports.
Explicit exclusion matching	resolved_paths_and_snapshot_filesystem_identities
Generated outputs and judge config excluded	Yes
Max entries	100000
Max file bytes	1000000
Max files	20000
Max total bytes	50000000
Requested scan ids	EXEC-05
Selected control ids	EXEC-05
Selected rule ids	AI014



Invocation and optional-review budgets

Setting	Configured value
Optional review / Analyst limits / Batch size	6
Optional review / Analyst limits / Investigation rounds	2
Optional review / Analyst limits / Max bytes	2000000
Optional review / Analyst limits / Max calls	36
Optional review / Analyst limits / Max chars	120000
Optional review / Analyst limits / Max files	200
Optional review / Analyst limits / Max seconds	600
Optional review / Cli login	auto
Optional review / Cli timeout seconds	Not configured
Optional review / Enabled	No
Optional review / Findings limit	100
Optional review / Include finding source	No
Optional review / Mode	full
Optional review / Provider	Not configured
Optional review / Transport replay	Endpoints, credentials, headers, executable paths and identity stores are not embedded for automatic replay.
Reporting / Failure threshold	high
Reporting / Formats	html, markdown, json, sarif, pdf
Review inputs / Baseline	No
Review inputs / Review config	No
Review inputs / Review report	No
Schema version	1.0

Image limits

Not present for this scan.

Source and image evidence are static. Image metadata, retained layers and packaged files do not reveal every runtime override or compiled program behavior.



Scanner provenance

Identity	Recorded value
Display name	Invarune by NimeshBuild
Implementation sha256	525747fc453830a4bc93b887c21161ff44c21212af1a525bbd5a9d615086954b
Name	agent-mcp-security-scan
Python version	3.12.14
Version	0.15.0



Deterministic checks and optional review

1 selected deterministic rules (1 active)

Deterministic checks inspect bounded Python syntax and local value flow, JavaScript/TypeScript lexical structure, structured JSON, configuration settings, selected secret patterns and image metadata. Repeated stable input produces repeatable evidence; it does not guarantee zero false positives or negatives.

Optional security analyst

If enabled, a model reviews selected findings and acceptance checks using bounded supplied evidence. Strict IDs, citations, response validation and tool restrictions constrain the protocol. Partial budgets, omitted answers and unavailable source/runtime evidence remain visible. Advice does not independently prove safety or erase static findings.

Review layer	Actual outcome / coverage
Finding review	Disabled; 0 selected; 0 outside cap
Control review	Disabled; 0/0 active controls answered
Unanswered acceptance checks	0/0 requested checks
Control requests	0/0 configured calls
Finding-stage error	None recorded
Control-stage errors	None

What can be missed

Cross-module/interprocedural flow, reflection, dynamic loaders, complex language syntax, templates before rendering, unsupported languages, compiled image behavior, runtime authentication/authorization, tenant isolation, egress policy, dependency CVEs and adaptive prompt injection require additional validation. A source declaration or proposed mitigation is not deployment evidence.

Human/runtime review workflow



1. Review evidence and the immediate concern. 2. Record a decision, reason, reviewer, date and evidence reference. 3. Validate runtime or human-dependent controls in the applicable environment. 4. Save and import the edited PDF or equivalent JSON. 5. Resolve rejected/stale edits, then rescan. Gaps remain operationally incomplete; blank decisions retain existing scanner semantics.



Coverage, misses and validation by area

Controls with rule mapping		1
Controls without rule mapping		0

Catalog mapping counts are not passed controls or percent secure.

Mapping counts describe available checks, not percent secure, detection accuracy or validated control effectiveness.

Execution and data flow

Deterministic: Python AST checks propagate selected registered-tool inputs and same-file arguments/returns, retain aliases and exact literal constraints, and check selected execution/file/network sinks. JavaScript tokens support narrow registerTool callbacks and direct-return named/arrow wrappers. Explicit world-writable chmod modes are checked.

Optional analyst: A model can form a trust-boundary hypothesis, request bounded captured source ranges to inspect callers or guards, seek counterevidence and explain what the supplied code still cannot establish.

Can miss or misclassify: Cross-file flows, unknown decorators/methods, complex JavaScript wrappers, dynamic imports, reflection, generated code and runtime values can hide a risk. Recognized resource/binding failures remain gaps. A dangerous API can be intentional and correctly constrained.

Validate elsewhere: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

Deterministic: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

Optional analyst: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

Can miss or misclassify: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

Validate elsewhere: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

Prompt injection, retrieval and memory

Deterministic: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

Optional analyst: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

Can miss or misclassify: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

Validate elsewhere: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

Deterministic: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

Optional analyst: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

Can miss or misclassify: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

Validate elsewhere: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

Skills and malicious-tool indicators

Deterministic: Bounded skill/tool/schema descriptions are checked for instruction hijacking, sensitive-data transfer, covert or approval-bypassing actions. Selected Spanish/French/German overrides and paired authority claims supplement English predicates. Python read-only tool annotations are compared with recognized direct write witnesses.

Optional analyst: A model can review intent, indirect social engineering, skill reference context and tool behavior visible in retrieved evidence, including cases where syntax or supported patterns are inconclusive.

Can miss or misclassify: A pattern is risk evidence, not proof of malicious authorship. Obfuscation, remote references, external packages, omitted context and runtime behavior can evade either layer.

Validate elsewhere: Inspect publisher provenance and the exact installed skill/tool; test consequential actions in an authorized isolated environment and verify effective permissions.



Built images and supply chain

Deterministic: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

Optional analyst: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

Can miss or misclassify: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

Validate elsewhere: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.

Operations and control effectiveness

Deterministic: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

Optional analyst: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

Can miss or misclassify: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

Validate elsewhere: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.

Optional-review audit details

Recorded field	Recorded value
Analyst / Enabled	No
Judge / Enabled	No



Appendix / Deterministic rule inventory

Only selected rules appear here. User-justified and disabled selections remain recorded in the decision audit and do not earn pass credit.

AI014 / Externally influenced outbound request

An outbound request uses an obvious external-input expression. This is a review signal for SSRF; this local analysis cannot prove whether upstream URL validation exists.



Interactive review workspace

Every bound item below remains tied to its original evidence. Blank means unreviewed. Any nonblank decision requires a reason; justified/disabled also require a reviewer. Coverage gaps cannot be justified or disabled. Runtime/human decisions identify outstanding validation and are not passes.

Long fields scroll in compatible PDF viewers. Save with regenerated appearances. If your editor flattens the form or cannot preserve it, use the JSON review workspace instead.

Acceptance check review

[Back to evidence](#)

EXEC-05:1 Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

Evidence binding: fd831b2d29a514ba09a917ddc9ad117f06287052030abc3272a928e2e58aff0d

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-05:2 Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

Evidence binding: a733931c250c834626baefc91c10f32a139dd325c5fd295fe6713285d66cc4b3

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE